IS04 — Information Security Awareness and Training Policy

[Company] IIoT Platform

Project name: [Company] Security Policies	Status: Active
Date: [Date]	Version: 1.0
Author: [Author Name]	Reviewer: [Reviewer Name]

Versions

Revision	Date	Author	Description
1.0	[Date]	[Author Name]	Initial release

Related Standards, Policies and Processes

- IS01 - [Company] Information Security Policy
- [Parent Company] - Corporate Security Awareness and Training Programme

Definitions and Terms

Definitions and terms used in this policy follow the SANS Institute Glossary of Security Terms.

Overview

Security is a broad and critical domain that demands active participation and awareness from all involved parties. Conducting regular awareness sessions and training programs is essential to strengthening the organization’s security posture and resilience. These initiatives not only enhance internal safeguards but also help ensure the security and integrity of the products and services delivered to our customers.

Purpose

The purpose of this policy is to establish a structured framework for promoting information security awareness and providing ongoing training to all employees, contractors, and third-party users. This ensures that individuals understand their responsibilities in protecting the organization's information

assets, are equipped to recognize and respond to potential security threats, and contribute to maintaining a strong and resilient security posture across the organization.

Scope

All employees, contractors, consultants, temporary and other workers of [Company] working on the [Company] IIoT Platform must adhere to this policy. This policy applies to all operations maintained and run on the [Company] platform and its components.

Policy

Employee responsibility

All employees are responsible for learning, understanding, and keeping up to date with the organization's information security practices and general security awareness. They are expected to:

- Participate in mandatory security training programs.
- Stay informed about emerging threats and best practices through provided awareness materials.
- Apply learned practices to their daily work activities.
- Promptly report any suspected security incidents or vulnerabilities.

[Company] Security Awareness Practices

As part of the ongoing security awareness efforts, biweekly security awareness meetings are held at [Company]. These sessions are designed to reinforce secure behavior, share current threat intelligence, and provide updates on internal and external security-related matters.

- A designated representative from the Security Team is responsible for preparing, organizing, and leading these meetings.
- Attendance is expected for all relevant employees, especially those with access to sensitive systems or data.
- Topics may include phishing trends, recent vulnerabilities, secure development practices, policy updates, and lessons learned from incidents.

In the event of a critical security incident or a significant threat observed in the wild, the Security Team is also responsible for issuing an official internal communication. This is typically delivered via email and will contain:

- A summary of the issue or threat.
- Immediate actions required (if any).
- Guidance or resources for further information.
- Contact points for reporting concerns or seeking clarification.

These activities support a proactive security culture and help ensure timely and informed responses across the organization.

Corporate security awareness programme

In addition to the [Company] internal security training requirements, all employees are also responsible for participating in and adhering to the security awareness and training programs mandated by the parent company (corporate). This includes:

- Completing all corporate-assigned security awareness modules and training sessions within the specified deadlines.
- Following corporate policies, standards, and guidelines related to information security.
- Staying informed of any updates or changes issued by the corporate security team.
- Ensuring alignment between internal practices and corporate security expectations.

Failure to comply with corporate training requirements may be considered a violation of this policy and subject to disciplinary action.

Policy Compliance

Compliance Measurement

The Security Team is responsible for verifying compliance with the Information Security Awareness and Training Policy. This ensures that all employees are actively participating in awareness activities and meeting training requirements.

Compliance will be measured through the following methods:

- **Recordings** of biweekly security awareness sessions.
- **Presentation materials** used during training and awareness meetings.
- **Email archives** of official internal security communications and training announcements.
- **Participation lists and attendance records** for awareness sessions and mandatory training modules.
- **Completion records** of both internal and corporate-mandated training programs.

Non-compliance, including failure to attend mandatory sessions or complete assigned training, may result in follow-up by the Security Team and, if necessary, escalation to management for corrective action.

This approach supports accountability, encourages continuous learning, and contributes to maintaining a strong security culture across the organization.

Exceptions

Any exception to the policy must be approved by the Security Team in advance.

Non-Compliance

An employee found to have violated this policy may be subject to disciplinary action.